
Plan Director de Seguridad para Anonym Construcciones SL.





Resumen

Nexus Consulting

Diciembre 2025 - Enero 2026

IES Camp de Morvedre

Obra publicada con [Licencia Creative Commons Reconocimiento Compartir igual 4.0](https://creativecommons.org/licenses/by-sa/4.0/)





Índice de Contenidos

1. Introducción y objetivos.....	4
2. Alcance y contexto.....	5
2.1 Alcance.....	5
2.2 Contexto.....	5
3. Metodología de análisis de riesgos.....	6
4. Inventario de activos.....	7
4.1 Activos de Datos.....	8
4.2 Activos de Hardware.....	9
4.3 Activos de Software.....	10
4.4 Activos de Personas.....	11
4.5 Activos de Servicios.....	12
4.6 Activos de Infraestructura.....	13
5. Análisis de amenazas y riesgos.....	14
5.1 Análisis de amenazas sobre los activos de datos.....	14
5.2 Análisis de amenazas sobre los activos de hardware.....	15
5.3 Análisis de amenazas sobre los activos de software.....	15
5.4 Análisis de amenazas sobre los activos de persona.....	15
5.5 Análisis de amenazas sobre los activos de servicios.....	16
5.6 Análisis de amenazas sobre los activos de infraestructura.....	16
6. Evaluación del riesgo.....	17
6.1 Criterios de valoración.....	17
6.2 Resultados de la evaluación.....	18
6.3 Conclusión de la evaluación.....	19
7. Plan de tratamiento del riesgo.....	19
7.1 Medidas de tratamiento propuestas.....	20
7.2 Seguimiento y revisión del tratamiento.....	21
8. Hoja de ruta y priorización.....	21
9. Gobernanza y seguimiento.....	25
10. Presupuesto/Propuesta económica.....	27
11. Anexos.....	29
Anexo I - Activos.....	29



1. Introducción y objetivos

En el contexto actual, caracterizado por una creciente digitalización de los procesos y una dependencia cada vez mayor de los sistemas de información, la ciberseguridad se ha convertido en un elemento estratégico para cualquier organización. La protección de la información, de los servicios y de los activos tecnológicos es esencial para garantizar la continuidad del negocio, el cumplimiento normativo y la confianza de usuarios y clientes.

El presente Plan Director de Seguridad (PDS) se elabora con el objetivo de establecer un marco global de gestión de la seguridad de la información, alineado con las necesidades de la organización y orientado a la identificación, análisis y tratamiento de los riesgos que puedan afectar a sus activos. Este documento permite disponer de una visión estructurada del estado actual de la seguridad, así como definir las acciones necesarias para mejorarla de forma progresiva y planificada.

El PDS actúa como un instrumento de referencia para la toma de decisiones en materia de ciberseguridad, proporcionando una hoja de ruta que integra medidas técnicas, organizativas y procedimentales. Asimismo, facilita la coordinación entre los distintos responsables y áreas implicadas, promoviendo una cultura de seguridad basada en la prevención, la concienciación y la mejora continua.

Los objetivos principales del presente Plan Director de Seguridad son los siguientes:

- Identificar y clasificar los activos de la organización, evaluando su nivel de criticidad y su importancia para la actividad del negocio.
- Analizar las amenazas y vulnerabilidades que pueden afectar a dichos activos, valorando los riesgos asociados en términos de impacto y probabilidad.
- Evaluar el nivel de riesgo existente y priorizar aquellos riesgos considerados altos o muy altos que requieren una actuación inmediata.



- Definir un plan de tratamiento del riesgo que contemple medidas adecuadas para reducir, mitigar, transferir o aceptar los riesgos identificados.
- Establecer una hoja de ruta que permita implantar las medidas de seguridad de forma ordenada y priorizada, teniendo en cuenta criterios técnicos, organizativos y económicos.
- Fomentar una gestión continua de la seguridad de la información, alineada con los objetivos estratégicos de la organización y orientada a la mejora constante de su nivel de protección.

Con este enfoque, el Plan Director de Seguridad se convierte en una herramienta clave para fortalecer la postura de ciberseguridad de la organización y garantizar la protección de sus activos frente a los riesgos actuales y futuros.

2. Alcance y contexto

2.1 Alcance

En cuanto al alcance tecnológico, se incluyen:

- Los sistemas de información utilizados para la gestión.
- Equipos informáticos y puestos de trabajo.
- Servidores, servicios en la nube y plataformas profesionales.
- Redes de comunicaciones y sistemas de almacenamiento.
- Aplicaciones software utilizadas en la empresa.
- Dispositivos portátiles y móviles de uso corporativo.

2.2 Contexto

La ciberseguridad sufre un incremento constante de las amenazas:

- **ataques de phishing**
- **malware**
- **ransomware**
- **accesos no autorizados**



- **fugas de información**

Además de estos ataques también hay que tener en cuenta el uso de las tecnologías en la nube que están expuestas a miles de personas aumentando los vectores de ataque .

El Plan Director de Seguridad se alinea con:

- **RGPD (Reglamento General de Protección de Datos).**
- **ENS (Esquema Nacional de Seguridad).**
- **MAGERIT** (análisis y gestión de riesgos.).
- **ISO/IEC 27001.**

Para poder cumplir con todas estas directrices Nexus Consulting ha identificado la necesidad de elaborar un Plan Director de Seguridad, que permita evaluar el estado de la seguridad y definir una estrategia cumpliendo siempre con las normativas establecidas.

3. Metodología de análisis de riesgos

La metodología de análisis de riesgos es el proceso mediante el cual una organización identifica, evalúa y trata los riesgos que pueden afectar a sus activos de información. Su finalidad es conocer qué amenazas pueden materializarse, cuál sería su impacto y qué medidas deben implantarse para reducir dichos riesgos a niveles aceptables.

En el ámbito de la ciberseguridad, el riesgo se entiende como la combinación de la probabilidad de que una amenaza ocurra y el impacto que tendría sobre los activos afectados. Este enfoque permite priorizar los esfuerzos de seguridad y aplicar medidas de forma proporcional a la importancia de cada activo.

Para el desarrollo del análisis de riesgos se utiliza la metodología MAGERIT, ampliamente adoptada en España y alineada con el Esquema Nacional de Seguridad (ENS). MAGERIT proporciona un marco estructurado y



sistemático que facilita la identificación de activos, amenazas y riesgos de manera coherente y justificada.

El primer paso del análisis consiste en la identificación de los activos, prestando especial atención a los activos de datos, considerados activos primarios, ya que contienen la información crítica para el negocio. Estos activos se valoran teniendo en cuenta las dimensiones de seguridad: confidencialidad, integridad y disponibilidad.

Una vez identificados y valorados los activos, se procede a la identificación de las amenazas que pueden afectarlos. Estas amenazas pueden ser intencionadas, como ataques de malware o phishing, o no intencionadas, como errores humanos o fallos técnicos. Cada amenaza se relaciona con los activos afectados y con las dimensiones de seguridad comprometidas.

El análisis del riesgo se realiza combinando el impacto del activo con la probabilidad de que la amenaza se materialice, utilizando la fórmula $\text{Riesgo} = \text{Impacto} \times \text{Probabilidad}$. Este cálculo permite clasificar los riesgos en distintos niveles y priorizar aquellos que requieren un tratamiento inmediato.

Finalmente, para cada riesgo identificado se definen salvaguardas o medidas de seguridad, que pueden ser preventivas, detectivas y correctivas. Estas medidas tienen como objetivo reducir el impacto o la probabilidad del riesgo y están alineadas con buenas prácticas y normativas como MAGERIT, el ENS y la ISO/IEC 27001.

4. Inventario de activos.

Como parte del Plan Director de Seguridad, se ha elaborado un inventario de activos que recoge de forma estructurada los distintos elementos que forman parte del sistema de información de la organización y sus posibles amenazas. El inventario completo se encuentra disponible en un archivo Excel, donde se detalla la información asociada a cada activo, incluyendo su identificación, descripción, responsable y nivel de criticidad.

https://gvaedu-my.sharepoint.com/:x:/r/personal/viccammar3_alu_edu_gva_es/_layouts/15/Doc.aspx?sourcedoc=%7B30DBE7E3-9C1C-488A-915D-A87BE0500BC9%7D&file=Inventario_activos.xlsx&action=default&mobileredirect=true



A continuación, se describen los principales tipos de activos inventariados, acompañados de capturas representativas de las tablas correspondientes.

4.1 Activos de Datos.

El inventario de activos de datos recoge la información gestionada por la organización, tanto en formato digital como en otros formatos, y que tiene valor para la actividad de la empresa. En la tabla se identifican los distintos conjuntos de datos, su descripción, el responsable de la información y su nivel de criticidad. Como ejemplo, pueden inventariarse bases de datos corporativas, información de clientes, datos económicos o documentación interna. Este tipo de activo es especialmente sensible, ya que su pérdida, alteración o divulgación no autorizada puede tener un impacto grave en la organización. En el Plan Director de Seguridad es fundamental proteger estos activos garantizando la confidencialidad, integridad y disponibilidad de la información, así como cumplir con la normativa vigente en materia de protección de datos.

ID Activo	Activo de Datos	Descripción
DA-01	Datos de clientes	Datos personales y contractuales de clientes
DA-02	Datos administrativos y fiscales	Facturas, impuestos, contabilidad
DA-03	Datos de empleados	Datos personales, contratos, nóminas
DA-04	Datos ERP Prinex	Base de datos central del negocio
DA-05	Datos de proveedores	Contratos y facturación de proveedores
DA-06	Documentación legal	Contratos, escrituras, acuerdos
DA-07	Información técnica de obras	Planos, proyectos, memorias técnicas
DA-08	Información comercial	Campañas y publicidad
DA-09	Correos electrónicos	Emails corporativos
DA-10	Copias de seguridad	Backups de información crítica

Aquí podemos ver por orden el departamento al que pertenece cada tipo de dato, su confidencialidad, integridad, disponibilidad y criticidad:

Departamento	Confidencialidad	Integridad	Disponibilidad	Criticidad
Comercial-Ventas	Muy Alta	Alta	Alta	Muy Alta
Administración-Finanzas	Alta	Muy Alta	Muy Alta	Muy Alta
RRHH-Gerencia	Muy Alta	Alta	Media	Muy Alta
Todos	Muy Alta	Muy Alta	Muy Alta	Muy Alta
Técnico-Administración	Media	Alta	Media	Alta
Gerencia	Alta	Alta	Media	Alta
Departamento Técnico	Media	Alta	Alta	Alta
Comercial	Baja	Media	Media	Muy Alta
Todos	Alta	Media	Alta	Alta
TI	Alta	Muy Alta	Muy Alta	Muy Alta



4.2 Activos de Hardware.

El inventario de activos hardware recoge todos los elementos físicos que forman parte del sistema de información de la organización, como servidores, equipos de usuario, dispositivos de red o sistemas de almacenamiento. En la tabla se identifica cada activo mediante un código único y se incluyen campos como la descripción del activo, su ubicación, el responsable asignado, el estado y el nivel de criticidad. Por ejemplo, se pueden inventariar servidores ubicados en una sala técnica concreta o equipos de sobremesa asignados a determinados puestos de trabajo. Este tipo de activos es especialmente crítico, ya que cualquier fallo físico, pérdida o acceso no autorizado puede afectar directamente a la disponibilidad de los servicios. Dentro del Plan Director de Seguridad es clave considerar la protección física, el mantenimiento, el control de accesos y la planificación del ciclo de vida de estos equipos.

ID Activo	Activo de Hardware	Descripción
HW-01	Servidor	PowerEdge Dell (torre) – RAID1, doble NIC, doble PSU. Alojamiento dominio, ERP y backups,
HW-02	Desktop	Dell OptiPlex – i5, 8GB RAM, SSD 128GB, Win10 Pro.
HW-03	Desktop	Dell OptiPlex – i5, 8GB RAM, SSD 128GB, Win10 Pro.
HW-04	Workstation	Dell Precision – i7, 16GB RAM, GPU dedicada, SSD 256GB.
HW-05	Portátil	Dell Latitude – variados modelos.
HW-06	Dispositivo Backup	Dell PowerVault (cinta). Realiza copias de seguridad.
HW-07	Router	Vigor 2927 (doble WAN, VPN, firewall).
HW-08	Switch	Switch Gigabit 24 puertos.
HW-09	Smartphone	Varias marcas (empresa).
HW-10	Almacenamiento USB	Unidades USB varias para intercambio de información.
HW-11	Equipos Obra	Portátiles + smartphones para obra.
HW-12	Periféricos	Monitores, teclados, ratones, impresoras.

Aquí podemos ver por orden el departamento al que pertenece cada equipo informático, su ubicación, propietario y criticidad:

Departamento	Ubicación	Propietario	Criticidad
Todos.	Sede central (sala servidor).	Administrador TI (externo).	Alta.
Comercial-Ventas.	Sede central – Departamento Comercial.	Paquí (Equipo comercial).	Media.
Administrativo-Financiero.	Sede central – Administrativo.	Ambrosio (Equipo administrativo).	Muy alta.
Técnico.	Sede central – Departamento Técnico.	Hermenegildo (Técnico).	Muy alta.
Técnico / Gerencia.	Movilidad / casetas obra.	Técnicos y gerencia.	Media.
Todos.	Sede central (junto a servidor).	Administrador TI (externo).	Alta.
Todos.	Sede central (rack comunicaciones).	Administrador TI (externo).	Alta.
Todos.	Sede central (rack).	Administrador TI (externo).	Media.
Todos.	Movilidad.	Varios empleados.	Baja.
Todos.	Uso compartido.	Todos los empleados.	Muy baja.
Construcción.	Casetas temporales.	Personal construcción.	Baja.
Todos.	Sede central y obras.	Varios empleados.	Muy baja.



4.3 Activos de Software.

Los activos software incluyen los sistemas operativos, aplicaciones corporativas y herramientas necesarias para el funcionamiento de la organización. El inventario permite identificar cada software mediante un identificador, describir su función, su responsable y el entorno en el que se utiliza. Por ejemplo, se pueden registrar sistemas operativos instalados en servidores, aplicaciones de gestión interna o herramientas utilizadas por los usuarios. Desde el punto de vista de la seguridad, este apartado es fundamental para tener controladas las versiones, licencias y dependencias entre sistemas. Una correcta gestión del software ayuda a reducir riesgos relacionados con vulnerabilidades conocidas, falta de actualizaciones o configuraciones inseguras que puedan comprometer la información.

ID	Activo Software	Tipo	Descripción
SW-01	Windows Server	Sistema Operativo	Sistema operativo del servidor principal
SW-02	Active Directory	Servicio	Gestión de usuarios, grupos y políticas de seguridad
SW-03	Windows 10/11 Pro	Sistema Operativo	Sistema operativo de los puestos de trabajo
SW-04	ERP Prinex	Aplicación	Gestión contable, facturación, clientes y proveedores
SW-05	Suite ofimática SaaS	Aplicación	Documentos, hojas de cálculo y presentaciones
SW-06	Correo electrónico corporativo	Servicio	Envío y recepción de correos corporativos
SW-07	Antivirus	Seguridad	Protección antimalware de equipos y servidor
SW-08	Software de copias de seguridad	Sistema	Gestión de backups diarios y semanales
SW-09	Almacenamiento en la nube	Servicio	Copia y almacenamiento externo de información
SW-10	Software de diseño técnico	Aplicación	Diseño de planos e imágenes técnicas
SW-11	Navegadores web corporativos	Aplicación	Acceso a servicios SaaS y web corporativa
SW-12	Portal web corporativo	Servicio	Web pública de la empresa
SW-13	CMS del portal web	Aplicación	Gestión de contenidos de la web
SW-14	Sistema operativo móvil	Sistema Operativo	SO de smartphones corporativos

Aquí podemos ver por orden el departamento al que pertenece cada software, su ubicación, propietario y criticidad:

Ubicación	Departamento	Propietario	Criticidad
Servidor central	TI	Empresa	Alta
Servidor central	Todos	Empresa	Alta
Equipos corporativos	Todos	Empresa	Media
Servidor / Cloud	Adm-Financiero	Empresa	Muy Alta
Cloud	Todos	Empresa	Alta
Cloud	Todos	Empresa	Alta
Equipos y servidor	Todos	Empresa	Alta
Servidor	TI	Empresa	Muy Alta
Cloud	Todos	Empresa	Alta
Workstations	Técnico	Empresa	Media
Equipos	Todos	Empresa	Media
Hosting externo	Comercial	Proveedor	Media
Hosting externo	Comercial	Proveedor	Media
Dispositivos móviles	Construcción	Empresa	Media



4.4 Activos de Personas.

El inventario de activos personas recoge los distintos perfiles humanos que interactúan con los sistemas de información, como empleados, personal técnico, administradores o colaboradores externos. En la tabla se definen aspectos como el rol, la función desempeñada y el nivel de acceso asociado a cada perfil. Por ejemplo, no tiene el mismo nivel de acceso un usuario estándar que un administrador de sistemas. Las personas son un activo clave para la organización, pero también uno de los principales vectores de riesgo. Por ello, en el Plan Director de Seguridad es esencial definir correctamente las responsabilidades, aplicar el principio de mínimo privilegio y tener en cuenta medidas de concienciación y formación en seguridad.

ID Activo	Activo de Personas	Descripción
PER-01	Paquí.	Encargada del departamento comercial-ventas. Gestiona clientes, campañas y recursos digitales.
PER-02	Ambrosio.	Responsable de la gestión administrativo-contable con el ERP Príncex.
PER-03	Clotilde (Directora).	Socia y directora. Responsable de RR.HH., área administrativo-financiera y legal.
PER-04	Luján.	Persona del área administrativo-financiera que ayuda en tareas de RR.HH. (pago de nóminas, selección, etc.).
PER-05	Hermenegildo (Socio).	Socio. Responsable del departamento técnico, dirección de obra y relación con proveedores.
PER-06	Personal técnico interno.	Técnicos contratados para dirección y supervisión de obras.
PER-07	Responsable de obra.	Personal de la empresa a cargo de la coordinación en cada promoción.
PER-08	Obreros.	Personal de construcción interno.
PER-09	Administrador TI (Externo).	Empresa o persona externa contratada para mantenimiento, soporte y seguridad TI.
PER-10	Asesoría fiscal.	Empresa externa que gestiona parte de los servicios financieros y fiscales.
PER-11	Asesoría laboral.	Empresa externa que gestiona nóminas y contratos.
PER-12	Empresa de desarrollo web.	Empresa externa que desarrolla y mantiene el portal web corporativo.

Aquí podemos ver por orden el departamento al que pertenece cada persona y su criticidad:

Departamento	Criticidad	Página
Comercial-Ventas.	Alta	9.
Administrativo-Financiero.	Alta	9.
Gerencia.	Muy alta.	9.
Administrativo-Financiero / RR.HH.	Media.	9.
Gerencia / Técnico.	Muy alta.	9.
Técnico.	Media.	9.
Construcción.	Media.	9.
Construcción.	Baja.	9.
IT (Externo).	Muy alta.	10, 11.
Administrativo-Financiero (Externo).	Alta.	9.
RR.HH. (Externo).	Alta.	9.
Comercial (Externo).	Media.	8.



4.5 Activos de Servicios.

Los activos de tipo servicio incluyen los servicios que soportan la actividad de la organización, tanto internos como externos. En el inventario se identifica cada servicio, su finalidad, su responsable y su nivel de criticidad. Como ejemplo, pueden incluirse servicios corporativos como el correo electrónico, el acceso a aplicaciones internas o servicios prestados por terceros. Estos activos suelen depender de otros activos hardware y software, por lo que su indisponibilidad puede tener un impacto elevado. En el Plan Director de Seguridad es importante evaluar la dependencia de proveedores externos, la disponibilidad del servicio y los posibles riesgos derivados de fallos, interrupciones o accesos no autorizados.

Activo de Servicios Externos	Descripción
Servicio de Administración TI Externa.	Mantenimiento, soporte y seguridad de sistemas informáticos.
Servicio de Telecomunicaciones (VodaTel).	Conexión a Internet y líneas telefónicas.
Servicio de Hosting Web.	Alojamiento y mantenimiento de portal web corporativo.
Servicio de Asesoría Fiscal.	Gestión de impuestos, contabilidad y obligaciones fiscales.
Servicio de Asesoría Laboral.	Gestión de nóminas, contratos y obligaciones laborales.
Servicio de Almacenamiento "on Cloud".	Copia de seguridad externa en la nube.
Servicio de Certificados Digitales.	Certificado SSL/TLS y firma electrónica.
Servicio de Mantenimiento Hardware.	Soporte y reparación de equipos informáticos.

Aquí podemos ver por orden el departamento al que pertenece cada servicio, su ubicación, propietario y criticidad:

Departamento	Ubicación	Propietario	Criticidad
Todos (TI).	Externa (Servicio remoto).	Gerencia.	Muy alta.
Todos.	Sede Central.	Gerencia.	Muy alta.
Comercial.	Externa.	Proveedor.	Media.
Administrativo-Financiero.	Externa.	Gerencia.	Alta.
RR.HH.	Externa.	Gerencia.	Alta.
Todos.	Cloud (Externa).	Gerencia.	Alta.
Todos.	Externa.	Administrador TI (externo).	Media.
Todos.	Externa.	Gerencia.	Media.



4.6 Activos de Infraestructura.

El inventario de activos de infraestructura recoge los elementos físicos que dan soporte al funcionamiento de los sistemas de información, como edificios, salas técnicas, racks, cableado o elementos de red física. Aunque estos activos no gestionan información de forma directa, su fallo puede provocar la interrupción total de los servicios. En la tabla se identifican y describen estos elementos para poder evaluar su importancia dentro de la organización. Desde el punto de vista de la seguridad, es fundamental considerar el control de accesos físicos, la protección frente a incidentes ambientales y la existencia de medidas de redundancia que garanticen la continuidad del negocio.

ID Activo	Activo de Infraestructura Física	Descripción
INF-01	Sede Central (Sala de Servidores)	Oficinas principales dónde trabajan todos los departamentos excepto construcción.
INF-02	Rack de comunicaciones	Armario dónde se encuentran los activos HW-07 y HW-08.
INF-03	Casetas temporales de obra	Oficinas móviles en obras para personal técnico y comercial.

Aquí podemos ver por orden el departamento al que pertenece cada infraestructura, su ubicación, propietario y criticidad:

Departamento	Ubicación	Propietario	Criticidad
Todos.	Sagunto.	Empresa.	Muy alta.
IT.	Sede Central.	Empresa.	Alta.
Construcción.	Obras (variable).	Empresa.	Media.



5. Análisis de amenazas y riesgos

El análisis de amenazas y riesgos tiene como finalidad identificar situaciones que pueden comprometer la seguridad de los activos de Nexus Consulting y generar impactos negativos sobre la confidencialidad, integridad y disponibilidad de la información y de los servicios. Este análisis ha sido realizado partiendo del inventario de activos que hemos desarrollado en el apartado 4. Para realizarlo hemos aplicado la metodología de MAGERIT teniendo en cuenta los principios del Esquema Nacional de Seguridad y la norma ISO/IEC 27001.

Para cada tipo de activo se han identificado las amenazas más relevantes teniendo su relevancia. En este documento solo se ha identificado las amenazas con un riesgo más alto, partiendo de la fórmula $\text{Riesgo} = \text{Probabilidad} \times \text{Impacto}$. La explicación de los valores numéricos junto con las demás amenazas, se encuentra detallada en el siguiente documento: [Enlace excel](#).

5.1 Análisis de amenazas sobre los activos de datos

Las principales amenazas que hemos identificado durante el análisis son:

- Accesos no autorizados: Probabilidad(3) x Impacto(4).
- Fuga de información: Probabilidad(3) x Impacto(5).
- Modificación indebida: Probabilidad(3) x Impacto(5).
- Indisponibilidad de la información: Probabilidad(3) x Impacto(5).
- Malware: Probabilidad(4) x Impacto(5).
- Phishing: Probabilidad(3) x Impacto(4).

Estas amenazas podrían provocar pérdidas económicas, sanciones legales por incumplimiento normativo o un impacto en la reputación de la empresa, ya que los riesgos están asociados a los datos de clientes y a los sistemas de gestión empresarial.



5.2 Análisis de amenazas sobre los activos de hardware

Las principales amenazas que hemos identificado durante el análisis son:

- Avería de origen físico: Probabilidad(3) x Impacto(4).
- Robo o pérdidas: Probabilidad(2) x Impacto(3).
- Corte del suministro eléctrico: Probabilidad(3) x Impacto(4).

Estos riesgos afectan principalmente a la disponibilidad de los sistemas y servicios. Podrían provocar interrupciones en la actividad empresarial, especialmente cuando se ven comprometidos los servidores principales o dispositivos portátiles utilizados por el personal.

5.3 Análisis de amenazas sobre los activos de software

Las principales amenazas que hemos identificado durante el análisis son:

- Vulnerabilidades técnicas: Probabilidad(3) x Impacto(4).
- Errores de configuración: Probabilidad(3) x Impacto(4).
- Alteración de la información: Probabilidad(3) x Impacto(5).

La explotación de estas amenazas podría facilitar ataques de malware, accesos no autorizados o fallos en servicios críticos, lo cual incrementa el nivel de exposición de la organización frente a incidentes de seguridad.

5.4 Análisis de amenazas sobre los activos de persona

Las principales amenazas que hemos identificado durante el análisis son:

- Errores humanos: Probabilidad(3) x Impacto(4).
- Ingeniería social: Probabilidad(4) x Impacto(4).
- Phishing dirigido a empleados: Probabilidad(4) x Impacto(4).

Estos riesgos podrían facilitar otros incidentes, como infecciones por malware, fugas de información o accesos indebidos a los sistemas, habría que tener más cuidado con los perfiles con mayores privilegios.



5.5 Análisis de amenazas sobre los activos de servicios

Las principales amenazas que hemos identificado durante el análisis son:

- Falta / Indisponibilidad del personal: Probabilidad(2) x Impacto(2).
- Denegación de servicios: Probabilidad(2) x Impacto(4).

Estas amenazas podrían provocar la interrupción de servicios, lo cual afectará al trabajo diario y a la capacidad de prestar nuestros servicios a los clientes.

5.6 Análisis de amenazas sobre los activos de infraestructura

Este apartado se va a dividir en posibles amenazas de origen físico y posibles amenazas de origen natural.

De origen físico:

Amenaza	Descripción	Activos afectados	Probabilidad	Impacto
Acceso físico no autorizado	Entrada de personal no autorizado a salas técnicas o zonas restringidas	Sala de servidores, racks, cableado.	Medio(3)	Medio(3)
Sabotaje intencionado	Daños deliberados en las instalaciones o en el cableado	Cableado, racks, CPD.	Medio(3)	Bajo(2)
Falta de mantenimiento	Deterioro de la infraestructura	Infraestructura general	Medio(3)	Medio(3)

De origen natural:

Amenaza	Descripción	Activos afectados	Probabilidad	Impacto
Cortes del suministro eléctrico	Interrupciones externas de energía eléctrica	CPD, racks, servidores	Medio(3)	Alto(4)
Incendios	Fuego en instalaciones o	Infraestructura	Bajo(1)	Muy alto(5)



	zonas cercanas	completa		
Desastres naturales	Terremotos, tormentas severas u otros fenómenos extremos	Infraestructura completa	Muy bajo(1)	Muy alto(5)

6. Evaluación del riesgo

La evaluación del riesgo tiene como finalidad identificar y valorar los riesgos que pueden derivar en la materialización de incidentes de ciberseguridad que afecten a los activos de la empresa. Esta evaluación constituye la base para anticipar los incidentes más probables y con mayor impacto, permitiendo establecer prioridades en las actuaciones de prevención, detección, respuesta y recuperación definidas en el presente Plan Director de Seguridad.

6.1 Criterios de valoración.

Escala de impacto

Nivel	Descripción
Muy bajo	Incidente menor sin afectación operativa ni económica.
Bajo	Pérdida limitada de información sin impacto económico relevante.
Medio	Afecta operaciones internas, con repercusión económica o legal leve.
Alto	Impacto significativo sobre la operativa del negocio.
Muy alto	Pérdida crítica, con impacto legal, financiero o estratégico grave.

Escala de probabilidad

Nivel	Descripción
Muy bajo	Prácticamente imposible, sólo en circunstancias excepcionales.
Bajo	Poco probable, registrado en casos aislados.



Medio	Posible, ha ocurrido alguna vez en el entorno o sector.
Alto	Muy probable, ocurre con cierta frecuencia.
Muy alto	Altamente probable en ausencia de medidas de control.

Matriz de riesgo resultante

Nivel	Descripción
Bajo	Riesgo aceptable. No requiere acción inmediata.
Medio	Riesgo moderado. Debe ser monitorizado y tratado a medio plazo.
Alto	Riesgo significativo. Requiere plan de tratamiento prioritario.
Muy alto	Riesgo crítico. Necesita medidas inmediatas para su reducción.

6.2 Resultados de la evaluación.

Tras el análisis detallado de los activos y amenazas identificados en el inventario, se han obtenido los siguientes resultados:

- Riesgos muy altos: 12 amenazas. Principalmente asociadas a:
 - Acceso no autorizado a datos de clientes y ERP.
 - Malware e ingeniería social en equipos administrativos.
 - Indisponibilidad del servidor principal y cortes eléctricos.
 - Robo o pérdida de portátiles y dispositivos móviles.
- Riesgos altos: 28 amenazas. Relacionados con:
 - Errores de configuración y administración.
 - Fugas de información por correo o servicios cloud.
 - Fallos en copias de seguridad y degradación de soportes.
 - Ataques de denegación de servicio y phishing.
- Riesgos medios: 18 amenazas. Incluyen:
 - Uso no autorizado de software técnico.
 - Errores de usuarios de herramientas ofimáticas.
 - Vulnerabilidades en aplicaciones web y CMS.
- Riesgos bajos: 7 amenazas. Corresponden a:
 - Incidentes menores de disponibilidad de personal.
 - Amenazas ambientales con baja probabilidad.



De acuerdo con los criterios establecidos por la dirección, se priorizará para tratamiento inmediato aquellos riesgos altos y muy altos asociados a activos clasificados como A y MA (Alto y Muy Alto).

6.3 Conclusión de la evaluación.

La evaluación de riesgos evidencia un nivel de exposición elevado en diversos ámbitos, debido principalmente a la ausencia de un Plan Director de Seguridad (PDS) formalizado, la insuficiencia de controles de seguridad básicos y la dependencia de servicios y personal externo.

Los resultados obtenidos constituyen la base para la definición del plan de tratamiento del riesgo y de los proyectos de seguridad orientados a la gestión de incidentes contemplados en el presente PDS.

7. Plan de tratamiento del riesgo

El plan de tratamiento del riesgo tiene como objetivo definir y aplicar las medidas necesarias para reducir, mitigar, eliminar o aceptar los riesgos identificados en la fase de evaluación, de acuerdo con su nivel de criticidad y con los criterios establecidos. Este plan se basa en los resultados obtenidos en la evaluación del riesgo y se centra en aquellos riesgos clasificados como **Muy Altos y Altos**, especialmente los asociados a activos críticos (A y MA).

Para cada riesgo identificado se determina la estrategia de tratamiento más adecuada, teniendo en cuenta el impacto potencial, la probabilidad de ocurrencia, el coste de las medidas y la viabilidad técnica y organizativa de su implantación. Las estrategias de tratamiento adoptadas se clasifican en las siguientes categorías:

- **Reducción del riesgo:** aplicación de controles técnicos, organizativos o procedimentales para disminuir la probabilidad de ocurrencia o el impacto del riesgo.
- **Evitar el riesgo:** eliminación de la actividad o del activo que genera el riesgo, cuando sea viable.
- **Transferir el riesgo:** delegación parcial del riesgo a terceros, por ejemplo mediante contratos, acuerdos de nivel de servicio (SLA) o seguros.



- **Aceptar el riesgo:** asunción del riesgo cuando su nivel es bajo o el coste del tratamiento es superior al impacto potencial.

7.1 Medidas de tratamiento propuestas.

En función de los principales riesgos detectados, se proponen las siguientes líneas de actuación:

- **Protección de los activos de datos:**
 - Implantación de controles de acceso basados en el principio de mínimo privilegio.
 - Cifrado de la información sensible, tanto en reposo como en tránsito.
 - Refuerzo de las políticas de copias de seguridad y pruebas periódicas de restauración.
 - Cumplimiento de la normativa vigente en materia de protección de datos.
- **Seguridad de los activos hardware y de infraestructura:**
 - Control de accesos físicos a salas técnicas y equipos críticos.
 - Mantenimiento preventivo de servidores y dispositivos de red.
 - Medidas de protección frente a cortes eléctricos y fallos ambientales.
 - Inventariado y etiquetado de dispositivos portátiles para reducir riesgos de pérdida o robo.
- **Gestión segura del software y servicios:**
 - Actualización periódica de sistemas operativos y aplicaciones.
 - Control de licencias y eliminación de software no autorizado.
 - Revisión de configuraciones para evitar vulnerabilidades conocidas.
 - Evaluación de proveedores externos y definición de acuerdos de seguridad.
- **Gestión del factor humano:**



- Programas de concienciación y formación en ciberseguridad para el personal.
- Definición clara de roles y responsabilidades.
- Procedimientos de alta, baja y modificación de usuarios.
- Medidas específicas frente a amenazas de ingeniería social y phishing.

7.2 Seguimiento y revisión del tratamiento

El plan de tratamiento del riesgo será revisado de forma periódica para verificar la eficacia de las medidas implantadas y adaptarlo a posibles cambios en el entorno tecnológico, organizativo o normativo. Los riesgos residuales resultantes tras la aplicación de los controles serán reevaluados y documentados, sirviendo como base para la hoja de ruta y la priorización de actuaciones del Plan Director de Seguridad.

Este enfoque garantiza una gestión sistemática y continua del riesgo, alineada con los objetivos estratégicos de la organización y orientada a mejorar de forma progresiva su nivel de seguridad.

8. Hoja de ruta y priorización

La priorización se ha realizado a partir del nivel de riesgo calculado conforme a la expresión **Riesgo = Impacto × Probabilidad**, utilizando una escala de valores de 1 a 5. A partir de este cálculo, los riesgos se han clasificado en los siguientes niveles:

- **P1 (Crítica):** Riesgo muy alto (≥ 16).
- **P2 (Alta):** Riesgo alto (12–15).
- **P3 (Media):** Riesgo medio (8–11).
- **P4 (Baja):** Riesgo bajo (< 8).

Las actuaciones del Plan Director se organizan en función de su prioridad (P1, P2 y P3) y del plazo de implantación previsto, permitiendo una ejecución progresiva, realista y alineada con las capacidades de la organización.

Horizonte temporal de implantación de las medidas



La implantación de las medidas definidas en la hoja de ruta del Plan Director de Seguridad se ha planificado teniendo en cuenta el nivel de prioridad asignado a cada actuación, la complejidad técnica de su ejecución y la disponibilidad de recursos de la organización. Con el objetivo de garantizar una aplicación realista y progresiva, se ha establecido un **horizonte temporal global de seis meses**, estructurado en distintas fases.

Las **medidas de prioridad P1 (críticas)** se implantarán de forma inmediata o a corto plazo, en un **periodo comprendido entre 0 y 3 meses**. Estas actuaciones están orientadas a reducir los riesgos más elevados y a proteger los activos más críticos de la organización, garantizando desde las primeras fases un nivel adecuado de seguridad de la información.

Las **medidas de prioridad P2 (altas)** se ejecutarán en un **plazo medio, entre los meses 3 y 6**, una vez consolidadas las medidas críticas. Estas acciones permiten reforzar los controles de seguridad, mejorar el gobierno de la información y aumentar la resiliencia de los sistemas frente a incidentes.

Por último, las **medidas de prioridad P3 (medias)** se abordarán de forma paralela o escalonada dentro del mismo **horizonte de seis meses**, priorizando aquellas de menor complejidad técnica o impacto organizativo. Estas medidas contribuyen a elevar el nivel de madurez del sistema de seguridad sin comprometer la ejecución de las actuaciones críticas.

Este planteamiento escalonado facilita una implantación ordenada, asumible por la organización y alineada con sus capacidades operativas, permitiendo además realizar un seguimiento continuo del grado de cumplimiento del Plan Director y realizar ajustes si fuese necesario.

Medidas de prioridad P1 (críticas)

En una primera fase se implantan las medidas críticas, orientadas a reducir de forma inmediata los riesgos **muy altos y altos**, especialmente aquellos relacionados con el robo de credenciales, la ingeniería social, la propagación de malware y la indisponibilidad de la información.

M-01. Autenticación multifactor y endurecimiento de accesos.

Se implantará autenticación multifactor (MFA) en los accesos al ERP, al correo electrónico corporativo, a los servicios en la nube y a los accesos remotos. Adicionalmente, se aplicarán políticas de contraseñas robustas y



controles de acceso adecuados, reduciendo significativamente el riesgo de phishing, suplantación de identidad y accesos no autorizados.

M-02. Plan de concienciación anti-phishing.

Se desarrollará un plan de formación y concienciación dirigido a los empleados, centrado en la detección de correos fraudulentos, técnicas de ingeniería social y buenas prácticas de seguridad. Este plan se iniciará de forma inmediata y tendrá carácter continuo, reforzándose periódicamente.

M-03. Copias de seguridad 3-2-1 y pruebas de restauración.

Se implementará una estrategia de copias de seguridad basada en el modelo 3-2-1, garantizando la existencia de copias locales, externas y una copia aislada u offline. Asimismo, se realizarán pruebas periódicas de restauración para asegurar la recuperabilidad de la información ante incidentes como la pérdida de datos o ataques de ransomware.

M-04. Protección antimalware y hardening de endpoints.

Se desplegará una solución de antivirus avanzado o EDR en servidores y equipos de usuario, complementada con medidas de endurecimiento tales como el bloqueo de macros, el control básico de dispositivos USB y la restricción de aplicaciones no autorizadas, reduciendo la superficie de ataque frente a malware.

M-05. Gestión de parches y actualizaciones.

Se establecerá un procedimiento de actualización periódica de sistemas operativos, Active Directory, ERP, CMS del portal web y navegadores, minimizando los riesgos derivados de vulnerabilidades conocidas y errores de mantenimiento.

M-06. Endurecimiento de Active Directory.

Se aplicará el principio de mínimo privilegio, la separación de cuentas administrativas, el uso de políticas de grupo (GPO) seguras y la auditoría de eventos, con el objetivo de reducir riesgos de suplantación, abuso de privilegios y accesos indebidos al dominio corporativo.

M-07. Seguridad del correo electrónico.

Se reforzará la seguridad del correo corporativo mediante la configuración de mecanismos SPF, DKIM y DMARC, junto con filtros antispam y el bloqueo de adjuntos potencialmente peligrosos, reduciendo el riesgo de phishing, malware y fuga de información.



M-18. Auditorías internas y seguimiento mediante KPIs.

Desde el inicio del plan se establecerá un sistema de seguimiento basado en indicadores clave de seguridad (KPIs) y auditorías internas periódicas, garantizando la supervisión continua del Plan Director y su correcta evolución.

Medidas de prioridad P2 (altas)

En una segunda fase se implementarán medidas de control, gobierno y continuidad, orientadas a reducir riesgos altos y consolidar la seguridad de los activos críticos.

M-08. Control de accesos por rol y trazabilidad en el ERP.

Se definirán roles y permisos adecuados en el ERP, junto con mecanismos de trazabilidad y auditoría de cambios, reduciendo el riesgo de modificación indebida de la información y facilitando la detección de incidencias.

M-09. Clasificación de la información y revisión de permisos.

Se establecerá una política de clasificación de la información y se revisarán los permisos de acceso a carpetas, servicios en la nube y documentación corporativa, minimizando el riesgo de fuga o divulgación no autorizada.

M-10. Política de retención y borrado de información.

Se definirá una política de conservación y eliminación de datos personales y corporativos en correo y servicios cloud, asegurando el cumplimiento de la normativa de protección de datos y reduciendo los riesgos asociados a la retención excesiva de información.

M-11. Control de proveedores y acuerdos de nivel de servicio (SLA).

Se revisarán los contratos y acuerdos de nivel de servicio con proveedores críticos (TI externo, hosting, servicios cloud y asesorías), incorporando controles de seguridad, responsabilidades y procedimientos de supervisión.

M-12. Segmentación básica de red y configuración segura.

Se mejorará la arquitectura de red mediante una segmentación básica y una configuración segura de router, switch y WiFi, reduciendo la propagación de malware y los accesos indebidos.



M-14. Medidas de continuidad eléctrica.

Se implantará un sistema de alimentación ininterrumpida (SAI) y procedimientos de apagado seguro, garantizando la continuidad de los servicios críticos ante cortes del suministro eléctrico.

M-15. Gestión de dispositivos móviles.

Se aplicarán medidas de cifrado, bloqueo y borrado remoto en dispositivos móviles corporativos, reduciendo los riesgos derivados de robo, pérdida o acceso no autorizado.

M-19. Simulacros de incidentes.

Se realizarán simulacros periódicos de phishing, restauración de copias de seguridad y caída de servicios, con el objetivo de validar la eficacia real de las medidas implantadas.

M-20. Revisión anual del análisis de riesgos.

Se actualizará anualmente el análisis de riesgos conforme a la metodología MAGERIT, ajustando prioridades y medidas en función de la evolución del contexto y de los activos de la organización.

Medidas de prioridad P3 (medias)

En una fase final se abordarán medidas de refuerzo y madurez del sistema de seguridad.

M-13. Seguridad física de la sala de servidores y del rack de comunicaciones.

Se reforzará el control de acceso físico mediante cerraduras, registros de acceso y, si procede, sistemas de videovigilancia.

M-16. Control avanzado de dispositivos USB y política de mesa limpia.

Se implementarán controles más estrictos sobre el uso de dispositivos USB y se reforzará la política de escritorio y pantalla limpia para evitar escapes de información.

M-17. Seguridad del portal web y del CMS.

Se aplicarán medidas de hardening del CMS, control de accesos al panel de administración, copias de seguridad y protecciones adicionales frente a vulnerabilidades web.

9. Gobernanza y seguimiento

Implica establecer una estructura de roles y responsabilidades para dirigir la implementación de políticas, procedimientos y medidas de



protección de activos, y luego monitorear continuamente su efectividad a través de auditorías, indicadores clave y reportes a la dirección para asegurar la alineación con los objetivos de negocios y la mejora continua, creando una cultura de ciberseguridad inclusiva.

Gobernanza del plan director

- **Liderazgo y compromiso:** Involucrar a la alta dirección para asegurar el apoyo estratégico y presupuestario, y fomentar una cultura donde la seguridad es responsabilidad de todos.
- **Marco organizativo:** Definir roles y responsabilidades claras para la gestión de la seguridad.
- **Alineación estratégica:** Asegurar que el PDS apoye los objetivos de negocio, identificando riesgos clave y priorizando inversiones en seguridad.
- **Políticas y procedimientos:** Establecer políticas claras, procedimientos operativos y controles técnicos y organizativos.

Seguimiento del plan director de seguridad

- **Análisis y evaluación:** Realizar evaluaciones periódicas de riesgos y vulnerabilidades para identificar brechas y nuevas amenazas.
- **Monitoreo continuo:** Utilizar indicadores clave de rendimiento y métricas para medir la eficacia de las medidas implementadas.
- **Reporte y comunicación:** Generar informes periódicos para la dirección sobre el estado de la seguridad, el progreso del plan y el retorno de la inversión.
- **Auditoría y revisiones:** Realizar auditorías internas y externas para verificar el cumplimiento y la efectividad de los controles.
- **Mejora continua:** Ajustar el plan basándose en los resultados del seguimiento y en los cambios en el entorno de amenazas, asegurando una actualización constante.



10. Presupuesto/Propuesta económica

Código	Proyecto/medida	Coste anual (€)	Prioridad	Justificación
P01.01	Autenticación Multifactor (MFA)	200	P1	Licencia software MFA (100€/año) + configuración (100€)
P01.02	Plan concienciación anti-phishing	800	P1	20h formación × 40€/h = 800€
P01.03	Copias 3-2-1 y pruebas restauración	600	P1	Cloud storage 3TB (600€/año)
P01.04	Protección antimalware avanzada	500	P1	Antivirus EDR básico (500€/año)
P01.05	Gestión de parches automatizada	300	P1	Herramienta gestión parches (300€/año)
P01.06	Endurecimiento Active Directory	400	P1	Consultoría especializada (10h × 40€)
P01.07	Seguridad correo (SPF, DKIM, DMARC)	150	P1	Configuración y mantenimiento
P02.01	Control accesos por rol en ERP	400	P2	Consultoría ERP (10h × 40€)
P02.02	Clasificación información	300	P2	Herramienta etiquetado + formación
P02.03	Política retención y borrado	200	P2	Software gestión documentos
P02.04	Revisión contratos proveedores	500	P2	Asesoría legal (10h × 50€)
P02.05	Segmentación básica de red	1200	P2	Router avanzado (275€) + Switch (100€) + configuración (825€)
P02.06	SAI y procedimientos apagado	1500	P2	SAI servidor (1.200€) + instalación (300€)
P02.07	Cifrado dispositivos móviles	300	P2	Software cifrado (100€) + gestión (200€)



P02.08	Simulacros incidentes	600	P2	15h preparación × 40€/h
P03.01	Seguridad física sala servidores	800	P3	Cerraduras, detector humo, etc.
P03.02	Política USB y mesa limpia	200	P3	Señalización + dispositivos cifrados
P03.03	Hardening portal web	400	P3	Auditoría seguridad web
P03.04	Auditorías internas y KPIs	1000	P3	25h auditoría × 40€/h
P03.05	Revisión anual análisis riesgos	600	P3	Actualización MAGERIT (15h × 40€)
	Gastos externos			
	Admin TI externo	2400	—	60h/año × 40€/h (ya existente)
	Firewall nuevo	1200	P1	Alquiler y soporte (según contexto)
	Nuevas medidas	9550		
	Medidas existentes	3600		
	Total anual	13150		

Versión para ajustarnos a los 10.000€ anuales

Prioridad	Presupuesto	Ajuste propuesto
P1 (Crítico)	3450€	Mantener completo
P2 (Alto)	5100€	Reducir en 1100€
P3 (Medio)	3000€	Reducir en 1450€
Total	11550€	9950€



11. Anexos

Anexo I - Activos

NOMBRE	APELLIDO	TIPO ACTIVO	NOMBRE ACTIVO	ID ACTIVO	D	C	I	T	AMENAZA	VAID	DEGRAD	IMPAC	PROBAS	RIESGO POT	SALVAGUARDAS PROPUESTAS	IMPAC R	PROB R	RIESGO RES	ISO-ENS	IMPAC A	PROB A	RIESGO ACEP
IVAN	ORTIZ	Datos	Datos de clientes	DA-01	A	MA	A	A	[A.12] Acceso no autorizado	XSS	M	A	M	A	Configuración MFA	M	B	M	6.15, 8.5	M	B	M
CÉSAR	RODRIGUEZ	Datos	Datos administrativos	DA-02	MA	MA	MA	A	[E.3] Modificación indebida	XSS	A	A	M	A	Concienciación empleados	M	M	M	8.2, 8.3	M	M	M
CÉSAR	RODRIGUEZ	Datos	Datos administrativos	DA-02	MA	MA	MA	A	[E.25] Pérdida de equipos (laptops)	XSS	MM	MM	M	MA	Redundancia sistemas	M	B	M	8.14, 7.11	M	B	M
CÉSAR	RODRIGUEZ	Datos	Datos ERP Primes	DA-04	MA	MA	MA	-	[I.2] Pérdida de la información	XSS	A	A	B	A	Backup 3-2-1	M	B	M	8.13, 8.14	M	B	M
CÉSAR	RODRIGUEZ	Datos	Copias de seguridad	DA-10	MA	MA	MA	M	[I.2] Fallo de backups	XSS	A	A	B	A	Pruebas restauración	M	B	M	8.13, 8.30	M	B	M
LUIS	ARAGON	Hardware	Desktop Administrativo	HW-03	MA	MA	MA	M	[E.1] Errores usuarios	XSS	A	A	A	MA	Formación específica	M	M	M	6.3, 8.18	M	M	M
LUIS	ARAGON	Hardware	Desktop Administrativo	HW-03	MA	MA	MA	M	[E.3] Modificación indebida	XSS	A	A	M	A	Controles integridad	M	M	M	8.3, 8.11	M	M	M
SAMY	ODEH	Hardware	Dispositivo Backup	HW-06	A	MA	MA	A	[I] Degradación soportes	XSS	A	A	M	A	Rotación medios	M	B	M	7.10, 8.13	M	B	M
SAMY	ODEH	Hardware	Dispositivo Backup	HW-06	A	MA	MA	A	[E] Errores monitorización	XSS	A	A	M	A	Verificación periódica	M	B	M	8.15, 8.13	M	B	M
ALEJANDRO	LUQUE	Software	Active Directory	SW-02	A	MA	A	A	[A.5] Suplantación identidad	XSS	A	A	M	A	MFA y policies	M	M	M	8.5, 8.16	M	M	M
ALEJANDRO	LUQUE	Software	Active Directory	SW-02	A	MA	A	A	[A.6] Abuso privilegios	XSS	A	A	M	A	Control cuentas privilegiadas	M	M	M	8.2, 8.18	M	M	M
ALEJANDRO	LUQUE	Software	ERP Primes	SW-04	MA	MA	MA	A	[E.3] Modificación indebida	XSS	A	A	M	A	Control accesos y backups	M	M	M	8.3, 8.13	M	M	M
ALEJANDRO	LUQUE	Software	ERP Primes	SW-04	MA	MA	MA	A	[A.12] Revelación de información	XSS	A	A	M	A	Clasificación información	M	M	M	5.12, 8.12	M	M	M
ALEJANDRO	LUQUE	Software	Software backups	SW-08	MA	MA	MA	-	[E] Errores monitorización	XSS	A	A	M	A	Revisión logs y alertas	M	B	M	8.15, 8.13	M	B	M
ALEJANDRO	LUQUE	Software	Software backups	SW-08	MA	MA	MA	-	[E] Destrucción información	XSS	A	A	B	A	Copias redundantes	M	B	M	8.13, 8.14	M	B	M
ERIC	MARCO	Personas	Ambrosio (Adm.)	PER-02	MA	MA	MA	A	[E.2] Errores administrador	XSS	A	A	M	A	Separación funciones	M	M	M	5.3, 8.18	M	M	M
ERIC	MARCO	Personas	Ambrosio (Adm.)	PER-02	MA	MA	MA	A	[A.23] Ingeniería social	XSS	A	A	M	A	Formación específica	M	M	M	6.3, 8.20	M	M	M
LUISA	RODRIGUEZ	Personas	Clotilde (Directora)	PER-03	MA	MA	MA	-	[A.22] Extorsión	XSS	A	A	B	A	Protección identidad	M	B	M	6.6, 8.5	M	B	M
LUISA	RODRIGUEZ	Personas	Clotilde (Directora)	PER-03	MA	MA	MA	-	[A.23] Ingeniería social	XSS	A	A	M	A	Concienciación alto nivel	M	M	M	6.3, 8.20	M	M	M
LUISA	RODRIGUEZ	Personas	Hernanegildo (Secio)	PER-05	MA	MA	MA	-	[A.18] Robo información	XSS	A	A	M	A	Protección dispositivos	M	M	M	7.9, 8.1	M	M	M
LUISA	RODRIGUEZ	Personas	Hernanegildo (Secio)	PER-05	MA	MA	MA	-	[A.23] Ingeniería social	XSS	A	A	M	A	Formación directivos	M	M	M	6.3, 8.20	M	M	M
LUISA	RODRIGUEZ	Personas	Admin TI (Externo)	PER-09	MA	MA	MA	A	[E.2] Errores administrador	XSS	A	A	M	A	Supervisión y auditoría	M	M	M	5.19, 8.18	M	M	M
LUISA	RODRIGUEZ	Personas	Admin TI (Externo)	PER-09	MA	MA	MA	A	[A.6] Abuso privilegios	XSS	A	A	M	A	Control acceso privilegiado	M	M	M	8.2, 8.18	M	M	M
ERIC	MARCO	Personas	Asesoría fiscal	PER-10	A	MA	A	-	[E.3] Errores configuración	XSS	A	A	B	A	Contratos y auditorías	M	B	M	5.20, 5.21	M	B	M
ERIC	MARCO	Personas	Asesoría fiscal	PER-10	A	MA	A	-	[A.13] Revelación de información	XSS	A	A	B	A	Cláusulas confidencialidad	M	B	M	5.20, 6.6	M	B	M
LUISA	RODRIGUEZ	Personas	Asesoría laboral	PER-11	A	MA	A	-	[E.3] Errores configuración	XSS	A	A	B	A	Contratos y auditorías	M	B	M	5.20, 5.21	M	B	M
LUISA	RODRIGUEZ	Personas	Asesoría laboral	PER-11	A	MA	A	-	[A.13] Revelación de información	XSS	A	A	B	A	Cláusulas confidencialidad	M	B	M	5.20, 6.6	M	B	M
MARINA	LOPEZ	Servicio	Admin TI Externa	SER-01	MA	MA	MA	A	[I.2] Avería hardware	XSS	A	A	M	A	SLA y monitorización	M	M	M	5.19, 5.20	M	M	M
MARINA	LOPEZ	Servicio	Admin TI Externa	SER-01	MA	MA	MA	A	[I.3] Corte eléctrico	XSS	A	A	M	A	Redundancia proveedor	M	B	M	5.20, 7.11	M	B	M
MARINA	LOPEZ	Servicio	Telecomunicaciones	SER-02	MA	M	MA	-	[I.3] Corte servicio internet	XSS	MM	MM	M	MA	Redundancia conexión	M	B	M	5.20, 8.20	M	B	M
MARINA	LOPEZ	Servicio	Telecomunicaciones	SER-02	MA	M	MA	-	[A.6] Ataque DDoS	XSS	A	A	M	A	Protección DDoS	M	B	M	8.20, 8.21	M	B	M
MARINA	LOPEZ	Servicio	Asesoría fiscal	SER-04	A	MA	A	-	[E.3] Pérdida/corrupción datos	XSS	A	A	B	A	Auditorías cumplimiento	M	B	M	5.20, 5.21	M	B	M
MARINA	LOPEZ	Servicio	Asesoría fiscal	SER-04	A	MA	A	-	[A.13] Revelación de información	XSS	A	A	B	A	Cláusulas contractuales	M	B	M	5.20, 6.6	M	B	M
MARINA	LOPEZ	Servicio	Asesoría laboral	SER-05	A	MA	A	-	[E.3] Pérdida/corrupción datos	XSS	A	A	B	A	Auditorías cumplimiento	M	B	M	5.20, 5.21	M	B	M
MARINA	LOPEZ	Servicio	Asesoría laboral	SER-05	A	MA	A	-	[A.13] Revelación de información	XSS	A	A	B	A	Cláusulas contractuales	M	B	M	5.20, 6.6	M	B	M
MARINA	LOPEZ	Servicio	Almacenamiento Cloud	SER-06	A	MA	MA	A	[I.2] Pérdida datos nube	XSS	A	A	B	A	Cifrado extremo a extremo	M	B	M	8.24, 8.13	M	B	M
MARINA	LOPEZ	Servicio	Almacenamiento Cloud	SER-06	A	MA	MA	A	[A.11] Acceso no autorizado	MA	A	A	M	A	Control acceso fuerte	M	B	M	8.5, 8.15	M	B	M

Estos son los activos valorados como críticos (Muy Alto) para la empresa. Para ver el resto del excel con todos los activos, accede a [\[Activos\]](#).